

EXECUTIVE CYBERSECURITY AND REGULATORY READINESS GUIDE

# Canada's Bill C-8
# Critical Cyber Systems Readiness

## A decision framework for exposure, evidence and 90-day action

Prepared for boards, CEOs, technology, security, risk, legal, operations and procurement leaders

Prepared by ROALLA Transformation and Technology Advisory

Status date: 13 November 2026

### Purpose

This guide helps leaders determine how Bill C-8 may affect the organization, translate statutory duties into operating capabilities and prepare decision evidence before phased regulations fully apply. It distinguishes direct designation from commercial supply-chain exposure and provides a practical path from uncertainty to accountable readiness.

EXECUTIVE DECISION DASHBOARD

# Management View at a Glance

Bill C-8 received Royal Assent on 15 June 2026. Telecommunications Act amendments took effect immediately; implementation of the Critical Cyber Systems Protection Act is phased. The executive task is to identify exposure, assign ownership and build a defensible readiness record while regulations and guidance continue to develop.

| Executive question | ROALLA view | Decision implication |
|---|---|---|
| **Could we be directly designated?** | **CONFIRM** | Map services, systems and federal jurisdiction; obtain legal confirmation. |
| **Could customer obligations flow down?** | **LIKELY** | Identify regulated customers, privileged access, service dependencies and contract clauses. |
| **Can we support a 72-hour ceiling?** | **TEST** | Exercise detection, triage, legal assessment, executive decisions and reporting inputs. |
| **Can we prove controls operate?** | **EVIDENCE** | Build a current evidence room tied to owners, tests, exceptions and remediation. |
| **What should management authorize?** | **90 DAYS** | Fund an exposure assessment, evidence baseline, vendor review and tabletop exercise. |

## Recommended Management Posture

Act on what is already useful and verifiable. Do not wait for perfect regulatory certainty to establish system ownership, incident decision rights, third-party visibility and evidence. Keep legal interpretation separate from technology delivery, and record every assumption that still requires confirmation.

> **Readiness is the ability to make and evidence the right decisions under pressure - not the possession of a policy binder.**

REGULATORY STATUS

# What Changed and What Remains Phased

Bill C-8, An Act respecting cyber security, amending the Telecommunications Act and making consequential amendments to other Acts, is now law. It creates the Critical Cyber Systems Protection Act and strengthens federal authority over telecommunications security.

| Element | Current executive interpretation | Action now |
|---|---|---|
| **Royal Assent** | 15 June 2026. | Treat the framework as enacted law, not a proposal. |
| **Telecommunications Act** | Amendments took effect upon Royal Assent. | Telecom organizations should confirm immediate implications with counsel and the regulator. |
| **CCSPA implementation** | Phased through regulations and designated classes. | Track regulations, designation and regulator guidance. |
| **Incident reporting** | The prescribed reporting period cannot exceed 72 hours. | Design an operating process that can meet the ceiling; validate final requirements when prescribed. |
| **Enforcement** | Inspections, compliance orders and administrative monetary penalties are available. | Ensure leaders can demonstrate governance and operating evidence. |

> **Do not describe every Canadian organization as directly regulated. Applicability depends on designation, class, system and jurisdiction. Supply-chain and customer expectations can still create material exposure.**

## Legal and Advisory Boundary

Qualified legal counsel should interpret applicability and legal duties. ROALLA's role is to help translate confirmed obligations and commercial expectations into architecture, operating controls, evidence, vendor governance and an executable roadmap.

APPLICABILITY AND EXPOSURE

# The Three Exposure Paths

A useful assessment looks beyond the legal entity and follows services, systems, customers, privileged access and critical dependencies.

| Exposure path | What it means | Evidence to review | Executive response |
|---|---|---|---|
| **1 Directly designated** | The organization operates a designated critical cyber system within a federally regulated vital service or system. | Legal entity, licences, service scope, system map, designation and regulator communications. | Confirm applicability and accountable officer; establish statutory readiness. |
| **2 Commercially connected** | The organization supplies technology or services to a designated operator and can affect the resilience of a critical system. | Customer portfolio, contracts, privileged access, integrations, hosting, data flows and subcontractors. | Prepare for contractual flow-down, assurance requests, incident notice and audit rights. |
| **3 Strategically affected** | The Act does not directly apply, but boards, insurers, lenders and customers raise the expected standard of care. | Risk appetite, insurance, procurement questionnaires, sales requirements and continuity commitments. | Use the framework to strengthen resilience and commercial credibility without claiming compliance. |

## Fast Applicability Questions

- Do we deliver a vital service or system under federal jurisdiction?
- Which customers operate in federal finance, telecommunications, energy or transportation?
- Can our product, platform or personnel interrupt, alter or expose a customer's critical system?
- Do we hold privileged credentials, sensitive telemetry, encryption keys or remote administration access?
- Could a material ownership, control or supplier change affect a critical dependency?
- Which assumptions must be confirmed by counsel, contract owners or a regulator?

SECTOR LENS

# Who Should Pay Close Attention

The framework is aimed at designated operators responsible for federally regulated vital services and systems. Regulations determine the designated classes and detailed requirements. Organizations that sell into these environments should also assess supplier exposure.

| Vital service or system | Leadership lens | Common supplier dependencies |
|---|---|---|
| **Banking systems** | Availability, integrity, payment operations, identity and concentration risk. | Cloud, SaaS, network, identity, fraud, data and managed services. |
| **Clearing and settlement** | Systemic dependency, transaction integrity and time-critical recovery. | Platforms, connectivity, security operations, data and specialist support. |
| **Telecommunications** | Network security, service continuity, supply-chain integrity and government directions. | Carriers, equipment, software, cloud, field service and operations support. |
| **Interprovincial or international energy** | Operational technology, remote access, safety, continuity and cross-border dependencies. | Industrial control, telecom, engineering, maintenance and cloud analytics. |
| **Nuclear energy** | Safety, security, controlled access, configuration and highly governed change. | Specialist technology, engineering, monitoring and service providers. |
| **Federally regulated transportation** | Safety, scheduling, operational technology, facilities and service disruption. | Fleet systems, logistics platforms, networks, terminals, cloud and vendors. |

> **A supplier does not need to be a designated operator to face higher assurance, notification, audit, data-location, subcontractor or continuity expectations from one.**

Commercial teams should connect cyber readiness to renewals, enterprise sales, procurement qualification and customer trust.

CONTROL FRAMEWORK

# Translate Duties into Operating Capabilities

A statutory obligation becomes useful only when leadership can identify the owner, operating process, evidence and decision threshold behind it.

| Duty area | Operating capability | Minimum decision evidence |
|---|---|---|
| **Cybersecurity program** | Govern, identify risks, protect systems, detect events, respond, recover and improve. | Approved program, owners, risk decisions, control results, exceptions and reviews. |
| **Critical systems and dependencies** | Maintain current scope across assets, data, identity, integrations, facilities and suppliers. | System register, service map, data flows, owners, recovery tiers and dependencies. |
| **Supply-chain risk** | Assess, contract, monitor and exit critical third parties. | Due diligence, clauses, access, subcontractors, incident obligations, alternatives and tests. |
| **Cyber incident reporting** | Detect, triage, assess, decide, notify and update within prescribed requirements. | Thresholds, clock ownership, facts, decisions, regulator contacts and submission records. |
| **Material changes** | Identify relevant ownership, control and supply-chain changes before completion. | Transaction/change intake, impact assessment, approvals and notification record. |
| **Directions and compliance** | Receive, authenticate, decide, execute and evidence required action. | Authority matrix, secure channels, action log, records and completion evidence. |

> **The control owner must be able to show what operates, how often, with what result, and what happens when the control fails.**

INCIDENT READINESS

# Design for the Reporting Clock

The legislation allows a prescribed reporting period of no more than 72 hours. The final trigger, recipient, content and update requirements must be confirmed, but the operating model can be tested now.

| Stage | Primary decision | Accountable role | Evidence produced |
|---|---|---|---|
| 01 Detect | Is an event credible and potentially material? | Security operations / service owner | Alert, timestamp, affected system and initial facts. |
| 02 Triage | Could the event affect a critical cyber system or vital service? | Incident commander | Scope, severity, containment and dependency view. |
| 03 Assess | Does the event meet legal or contractual reporting thresholds? | Legal / privacy / regulatory | Threshold analysis, assumptions and decision time. |
| 04 Authorize | Who approves the report and customer communications? | Named executive | Decision record, approved facts and recipients. |
| 05 Report | Can required information be submitted securely and on time? | Regulatory liaison | Submission, confirmation, updates and regulator questions. |
| 06 Learn | What must change after containment and recovery? | Risk owner | Lessons, corrective actions, owners and target dates. |

## Tabletop Exercise Injects

- The affected SaaS vendor cannot confirm whether customer data was accessed.
- The incident begins Friday evening and the designated executive is unavailable.
- Operations want to restore service before forensic evidence is preserved.
- A customer requests notice before legal has confirmed the reporting threshold.
- The system owner and vendor disagree on when the reporting clock began.
- Media inquiry arrives while facts remain incomplete.

THIRD-PARTY RISK

# Govern the Critical Supply Chain

A third-party register is not enough. Leadership needs to know which vendors can affect a critical outcome, what access they hold, how failure will be detected and what alternatives exist.

| Control question | Good evidence | Red flag |
|---|---|---|
| **What can this supplier affect?** | Mapped services, systems, data, access and business impact. | All vendors receive the same low-detail assessment. |
| **Who can access production?** | Named identities, MFA, least privilege, logging, reviews and rapid removal. | Shared accounts, unmanaged remote access or unknown subcontractors. |
| **How are incidents handled?** | Notice thresholds, timeframes, cooperation, evidence and communications clauses. | Vendor decides whether and when the customer is informed. |
| **Can the service recover?** | Tested recovery, realistic targets, customer dependencies and manual alternatives. | Recovery objectives exist only in marketing material. |
| **Can we change or exit?** | Data portability, transition support, credential removal and viable alternatives. | No tested exit path or excessive concentration. |
| **How are material changes found?** | Contract notice, ownership monitoring and architecture/change governance. | Acquisitions, hosting or subcontractors can change without notice. |

> **Prioritize third parties by consequence and access. A small supplier with privileged production access may matter more than a large vendor providing a non-critical tool.**

EVIDENCE AND ASSURANCE

# Build the Readiness Evidence Room

A credible program produces evidence as work occurs. The evidence room should be controlled, current, searchable and tied to owners and review dates.

| Evidence domain | Core artefacts | Executive test |
|---|---|---|
| **Scope and ownership** | Critical-system register, service map, data flows, owners and decision rights. | Can we name one accountable executive for each critical outcome? |
| **Risk and controls** | Risk assessments, control design, tests, exceptions and treatment plans. | Can we distinguish documented controls from operating controls? |
| **Incident readiness** | Plans, contacts, thresholds, exercises, submissions and lessons. | Can the team make a reportable-event decision under time pressure? |
| **Third parties** | Inventory, due diligence, access, contracts, monitoring, continuity and exit plans. | Which supplier failures would stop a vital service? |
| **Recovery** | Backups, restoration tests, recovery objectives, reconciliation and workarounds. | Has recovery been proven at the required scale and speed? |
| **Governance** | Minutes, approvals, metrics, funding decisions and remediation tracking. | What changed because leaders reviewed the evidence? |

**SOC 2 and ISO 27001 may contribute useful evidence. Neither automatically proves Bill C-8 applicability or compliance.**

90-DAY READINESS ROADMAP

# Move from Uncertainty to Accountable Action

Use a focused readiness cycle to establish exposure, build the evidence baseline and exercise the operating model. This is preparation for decisions, not a claim of compliance.

| Period | Leadership outcome | Priority actions | Decision gate |
|---|---|---|---|
| **Days 1-30** | **Determine exposure** | Map services, federal-sector customers, candidate critical systems and dependencies. Name the sponsor and legal lead. Record assumptions requiring confirmation. | Scope and accountability approved. |
| **Days 31-60** | **Build the evidence base** | Compare controls to duties. Map incident decisions. Review vendor access and contracts. Create a prioritized remediation register with funding ranges. | Material gaps and risk acceptance visible. |
| **Days 61-90** | **Exercise and govern** | Run a cyber tabletop. Test escalation and evidence collection. Assign funded owners and dates. Establish quarterly executive reporting. | Roadmap authorized and monitored. |

## Minimum Deliverables by Day 90

- Applicability and supply-chain exposure memorandum
- Critical-system and dependency map
- Executive accountability and incident authority matrix
- Control and evidence gap assessment
- Critical-vendor risk and contract review
- Tabletop results and corrective-action register
- Funded remediation roadmap
- Quarterly readiness scorecard and regulatory watch owner

**Sequence work by consequence, reporting readiness and evidence gaps - not by whichever security tool is easiest to purchase.**

EXECUTIVE READINESS ASSESSMENT

# Ten Questions for Leadership

Score each statement from 0 to 3: 0 unknown, 1 documented, 2 operating, 3 tested with current evidence. Use the result to prioritize discussion; it is not a certification.

| # | Readiness statement | 0 | 1 | 2 | 3 |
|---|---|---|---|---|---|
| 01 | We have a documented applicability position with assumptions and confirmation owners. | □ | □ | □ | □ |
| 02 | Critical services, systems, data flows and dependencies are current and owned. | □ | □ | □ | □ |
| 03 | One executive is accountable for the cybersecurity program and readiness reporting. | □ | □ | □ | □ |
| 04 | Incident thresholds, reporting-clock ownership and authorization are unambiguous. | □ | □ | □ | □ |
| 05 | The incident team can collect decision-quality facts inside the reporting window. | □ | □ | □ | □ |
| 06 | Critical third parties are prioritized by consequence, access and concentration. | □ | □ | □ | □ |
| 07 | Vendor contracts support notice, cooperation, evidence, continuity and exit. | □ | □ | □ | □ |
| 08 | Recovery has been tested against business requirements, not only technical success. | □ | □ | □ | □ |
| 09 | Control exceptions and remediation are visible to the appropriate executive forum. | □ | □ | □ | □ |
| 10 | Regulatory changes have a named owner and a process for translating them into action. | □ | □ | □ | □ |

| Score | Interpretation | Management response |
|---|---|---|
| 0-10 | Unstructured | Establish scope, ownership and incident authority immediately. |
| 11-20 | Developing | Close material evidence and third-party gaps before adding complexity. |
| 21-26 | Operating | Exercise the program and strengthen weak dependencies. |
| 27-30 | Demonstrated | Maintain assurance, horizon scanning and continuous improvement. |

BOARD AND EXECUTIVE REPORTING

# Report Readiness, Not Security Activity

Executives need measures that expose decision risk and operating capability. Tool counts and generic alert volumes rarely show whether a critical service is governable under pressure.

| Decision area | Useful indicator | Trigger for executive attention |
|---|---|---|
| **Scope** | % of critical services with current system, data and dependency maps. | Material service lacks an accountable owner or current map. |
| **Incidents** | Time from detection to materiality decision; exercise completion and corrective actions. | Decision path cannot meet the prescribed ceiling or facts are unavailable. |
| **Third parties** | % of critical suppliers assessed; privileged access reviewed; high-risk contracts remediated. | Uncontrolled access, missing notice rights or no viable continuity option. |
| **Recovery** | % of critical services meeting tested recovery objectives. | Test failure, integrity gap or untested dependency. |
| **Controls** | Material exceptions by age, risk and accountable owner. | Repeated overdue exception or accepted risk outside authority. |
| **Change** | Material ownership, architecture and supplier changes assessed before implementation. | Change proceeds without impact assessment or notification decision. |
| **Regulatory watch** | Open legal/regulatory assumptions and days since review. | New rule or designation lacks business and technology owner. |

> **A strong dashboard makes ownership, exceptions, time pressure and unproven recovery visible before an incident does.**

ROALLA ADVISORY MODEL

# How ROALLA Can Help

ROALLA coordinates the business and technology work required to turn confirmed obligations and customer expectations into an owned readiness program. Legal interpretation remains with qualified counsel.

| Workstream | ROALLA contribution | Leadership outcome |
|---|---|---|
| **Exposure and decision framing** | Map services, customers, systems, suppliers and assumptions; coordinate legal and operating inputs. | A defensible scope and prioritized decision agenda. |
| **Architecture and dependency mapping** | Connect critical outcomes to applications, data, identity, infrastructure, integrations and third parties. | Visibility into concentration, access and failure paths. |
| **Control and evidence readiness** | Translate duties into owners, processes, tests, artefacts and remediation requirements. | An evidence-based roadmap rather than a tool list. |
| **Incident and continuity readiness** | Design decision rights, reporting inputs, tabletop exercises, recovery tests and corrective actions. | Faster, more consistent decisions under pressure. |
| **Vendor and commercial governance** | Review supplier risk, contracts, operating responsibilities, alternatives and lifecycle economics. | Reduced dependency risk and stronger customer assurance. |
| **Executive roadmap and monitoring** | Sequence investment, owners, measures and quarterly reviews; monitor evolving opportunities and obligations. | A funded program connected to business priorities. |

**ROALLA does not guarantee compliance and does not replace legal counsel. We help leaders organize the technology, operating model, vendors, evidence and implementation required to act responsibly.**

## Turn regulatory uncertainty into an owned readiness plan.

Start a confidential executive conversation at roalla.com/contact

DISCUSS

SOURCES AND IMPORTANT NOTES

# Primary Sources and Use of This Guide

Use enacted legislation, regulations and the responsible federal authorities as the source of truth. Requirements will become more specific as implementation proceeds.

**01 Public Safety Canada**

Government of Canada strengthens cyber security and critical infrastructure with Royal Assent of Bill C-8, 16 June 2026.

**02 Parliament of Canada**

Bill C-8 Royal Assent text, 45th Parliament, 1st Session.

**03 LEGISinfo**

Bill C-8 status, legislative history and related documents.

**04 Library of Parliament**

Legislative Summary of Bill C-8.

## Important Notes

- This guide is general executive advisory information and is not legal advice, a compliance opinion or a certification.
- Applicability, designation, prescribed reporting periods, implementation dates and regulator-specific requirements must be confirmed for the organization.
- Maximum administrative monetary penalties stated in the Act can reach $500,000 for an individual and $15 million for another person or organization. Enforcement application depends on the law and circumstances.
- No funding, certification, legal outcome or regulatory acceptance is guaranteed by ROALLA.
- The guide reflects information available as of 13 November 2026 and should be reviewed when new regulations or guidance are issued.

## Executive decision support from ROALLA

Technology architecture • cybersecurity • vendor governance • readiness • implementation